

30 JUL 2023

US\$ 70M

Curve Finance

— "O código estava certo. O bytecode, não."

COMPILER BUG · CRITICAL

Bug no compilador Vyper — o reentrancy guard existia no código mas não no bytecode

O QUE ACONTECEU

Curve Finance é um dos maiores DEXs do ecossistema DeFi, escrito em **Vyper** (alternativa ao Solidity para a EVM).

Os desenvolvedores usaram o decorator **@nonreentrant('lock')** — a forma correta de proteger funções contra reentrância em Vyper.

O problema: versões do compilador Vyper entre **0.2.15 e 0.3.0** tinham um bug que fazia o reentrancy guard **não ser incluído no bytecode gerado**.

O código-fonte estava correto. A proteção estava declarada. Mas o **bytecode compilado não tinha o lock**. O atacante explorou essa falha via reentrância clássica em múltiplas pools.

03

CONTRATO VULNERÁVEL (VYPER)

```
...
e! #
reentrancy guard # → Reentrância possível mesmo com #
@nonreentrant declarado
```

Lição

Congele a versão do compilador e teste o bytecode gerado — o código-fonte nem sempre reflete o que roda on-chain.

04

COMO O ATAQUE FUNCIONOU

CONTEXTO

Curve pools compiladas com Vyper 0.2.15–0.3.0

**PASSO 1**

Atacante chama `remove_liquidity()`

**PASSO 2**

Pool envia ETH via callback

**PASSO 3**

@nonreentrant deveria bloquear...

MAS o lock não existe no bytecode!

**PASSO 4**

Atacante reentra via `add_liquidity()`

Estado inconsistente → preço manipulado

**RESULTADO**

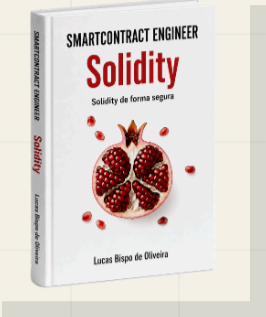
US\$70M drenados de múltiplas pools

aETH-ETH, msETH-ETH, pETH-ETH afetadas

VERIFIQUE NA BLOCKCHAIN

Transação do Ataque
etherscan.io/tx/0xa84aa0...620c

Curve a1ETH Pool
etherscan.io/address/0xc4C31...784e



Solbook — Smartcontract Engineer

Entenda a stack completa de segurança — do código-fonte ao bytecode